

CYBERSECURITY AND INFRASTRUCTURE SECURITY AGENCY (CISA)

Joint Cybersecurity Advisory | Alert Code: AA24-105A

PRC State-Sponsored Actors (Volt Typhoon) Target U.S. Critical Infrastructure via Living-off-the-Land Techniques

Release Date: February 2024 | Dissemination: TLP:CLEAR | Target Sectors: Energy, Water, Transportation, Defense

EXECUTIVE SUMMARY

The Cybersecurity and Infrastructure Security Agency (CISA), National Security Agency (NSA), and Federal Bureau of Investigation (FBI) are releasing this joint Cybersecurity Advisory (CSA) to warn critical infrastructure organizations of ongoing malicious activity attributed to the People's Republic of China (PRC) state-sponsored cyber group known as **Volt Typhoon** (also tracked as BRONZE SILHOUETTE and Vanguard Panda). Volt Typhoon targets critical infrastructure networks across the United States, including communications, energy, transportation systems, and water facilities. The adversary's choice of targets and pattern of behavior indicates that Volt Typhoon is pre-positioning access to disrupt operational technology (OT) and critical IT assets in the event of major geopolitical conflicts.

CRITICAL ACTION REQUIRED: Network defenders are strongly urged to review internet-facing edge appliances, enforce phishing-resistant MFA, and immediately ingest the Indicators of Compromise (IoCs) in Appendix A into enterprise perimeter blocklists.

TECHNICAL ANALYSIS: INITIAL ACCESS & EDGE EXPLOITATION

Volt Typhoon gains initial access primarily by exploiting zero-day and public-facing vulnerabilities in enterprise edge gateways and SOHO network appliances. Recent intrusions demonstrated weaponization of **CVE-2023-46805** (authentication bypass) and **CVE-2024-21887** (command injection) affecting Ivanti Connect Secure VPNs, as well as vulnerabilities in Fortinet FortiOS and Cisco RV320/RV325 routers. Upon perimeter compromise, the actors establish web shells and deploy Fast Reverse Proxy (FRP) tooling to tunnel malicious traffic through a vast covert operational network composed of compromised customer-premises equipment (CPE) across multiple global telecommunications providers.

ATTACK METHODOLOGY & PERSISTENCE (LIVING-OFF-THE-LAND)

A hallmark of Volt Typhoon operations is the strict reliance on built-in administrative utilities—commonly termed **Living-off-the-Land (LotL)**—to avoid detection by endpoint detection and response (EDR) sensors. Rather than deploying customary malware implants, the group abuses native Windows binaries such as wmic.exe, powershell.exe, netsh.exe, and nltest.exe. To establish persistent administrative access, the adversary modifies Windows registry run keys and schedules proxy services under the following paths:

- HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\VoltSvc
- HKEY_LOCAL_MACHINE\SYSTEM\CurrentControlSet\Services\PortProxy

The actors routinely utilize netsh interface portproxy commands to relay port traffic across segmented subnets, disguising lateral traversal as legitimate internal telemetry.

MITRE ATT&CK; MAPPING

Tactic	Technique ID	Technique Name	Adversary Implementation
Initial Access	T1190	Exploit Public-Facing Application	Exploitation of CVE-2023-46805 & CVE-2024-21887 on VPNs
Execution	T1059.001	PowerShell	Execution of encoded recon scripts and staging commands
Persistence	T1547.001	Registry Run Keys / Startup	Autostart entry in HKLM\Software\Microsoft\Windows\CurrentVersion\Run
Defense Evasion	T1070	Indicator Removal on Host	Deletion of shadow copies and clearing security event logs via wevtutil
Command and Control	T1071.001	Web Protocols	HTTP/HTTPS beaconing through compromised SOHO proxy nodes

APPENDIX A: INDICATORS OF COMPROMISE (IoCs)

All network and host-based indicators listed below have been confirmed in active intrusions. Indicators are defanged to prevent accidental resolution. Firewall engineers and SOC analysts should refang and block immediately across boundary inspection systems.

Indicator Type	Observed Indicator (Defanged)	Role / Association	Severity
IPv4	198[.]51[.]100[.]45	C2 Operational Proxy Node (Volt Typhoon)	High
IPv4	203[.]0[.]113[.]19	Compromised SOHO Router Egress Node	High
IPv4	192[.]0[.]2[.]88	Staging & Exfiltration Relay	High
IPv4	198[.]18[.]0[.]14	Reverse Proxy Listener	Medium
Domain	vpn-telemetry-sync[.]com	Adversary C2 Callback Domain	High
Domain	cloud-gateway-update[.]net	Dynamic DNS Resolver Host	High
URL	hxxp://vpn-telemetry-sync[.]com/api/v1/health	Heartbeat Beacon Endpoint	High
SHA-256	e3b0c44298fc1c149afb4c8996fb92427ae41e4649b934ca495991b7852b855	Webshell / Dropper Utility	High
SHA-256	2c26b46b68ffc68ff99b453c1d30413413422d706483bfa0f98a5e886266e7ae	Fast Reverse Proxy (FRP) binary	High
MD5	d41d8cd98f00b204e9800998ecf8427e	Staging payload hash	Medium
Registry Key	HKLM\SOFTWARE\Microsoft\Windows\CurrentVersion\Run\VoltSvc	Adversary Persistence Mechanism	High
CVE	CVE-2023-46805	Ivanti ICS Auth Bypass Zero-Day	Critical
CVE	CVE-2024-21887	Ivanti ICS Web Command Injection	Critical